

MIGUEL ANGEL SALAZAR MARTINEZ

Universidad Politécnica de San Luis Potosi

CNO 4 – Seguridad Informática

Profesor: Servando López Contreras

Actividad 9 – File Path Traversal | Traversal
sequences stripped non-recursively

23/09/26

Introducción

En el ámbito de la ciberseguridad, el juego entre ataque y defensa a menudo se decide en los detalles. En la sección anterior vimos cómo evadir un filtro simple mediante rutas absolutas; ahora, el escenario que nos ocupa va un paso más allá: el desarrollador no solo filtra las secuencias de path traversal, sino que intenta eliminarlas por completo. Sin embargo, cuando esta eliminación se ejecuta una sola vez (no recursiva), el atacante puede aprovechar secuencias anidadas para "reconstruir" los caracteres prohibidos. Este caso revela de forma profunda el defecto fundamental de las defensas basadas en listas negras: siempre asumen que el atacante construirá la entrada maliciosa de una sola manera, mientras que un atacante real buscará combinaciones fuera de las reglas. Comprender este principio de bypass es esencial para diseñar mecanismos de validación de rutas verdaderamente robustos.

Marco Teórico

El mecanismo de la eliminación no recursiva y su falla

El núcleo de este laboratorio es la "eliminación no recursiva" como estrategia de defensa. La aplicación, al recibir el nombre de archivo proporcionado por el usuario, detecta si contiene la secuencia ../ y, si existe, la elimina. Sin embargo, esta operación de eliminación se ejecuta una sola vez, sin volver a escanear la cadena resultante para comprobar si se ha generado una nueva secuencia peligrosa.

El principio de reconstrucción mediante secuencias anidadas

El atacante puede construir una carga útil como//. Cuando la aplicación realiza una eliminación, detecta la secuencia ../ dentro de la cadena y la elimina. Pero al hacerlo, los caracteres que estaban separados se recombinan, formando exactamente una nueva secuencia.

Encadenando múltiples secuencias anidadas de este tipo, el atacante puede construir//....//....//etc/passwd. La operación de eliminación de la aplicación convertirá cada// en ../, dando como resultado final ../..../etc/passwd, logrando así el directory traversal.

La contradicción fundamental con las defensas de lista negra

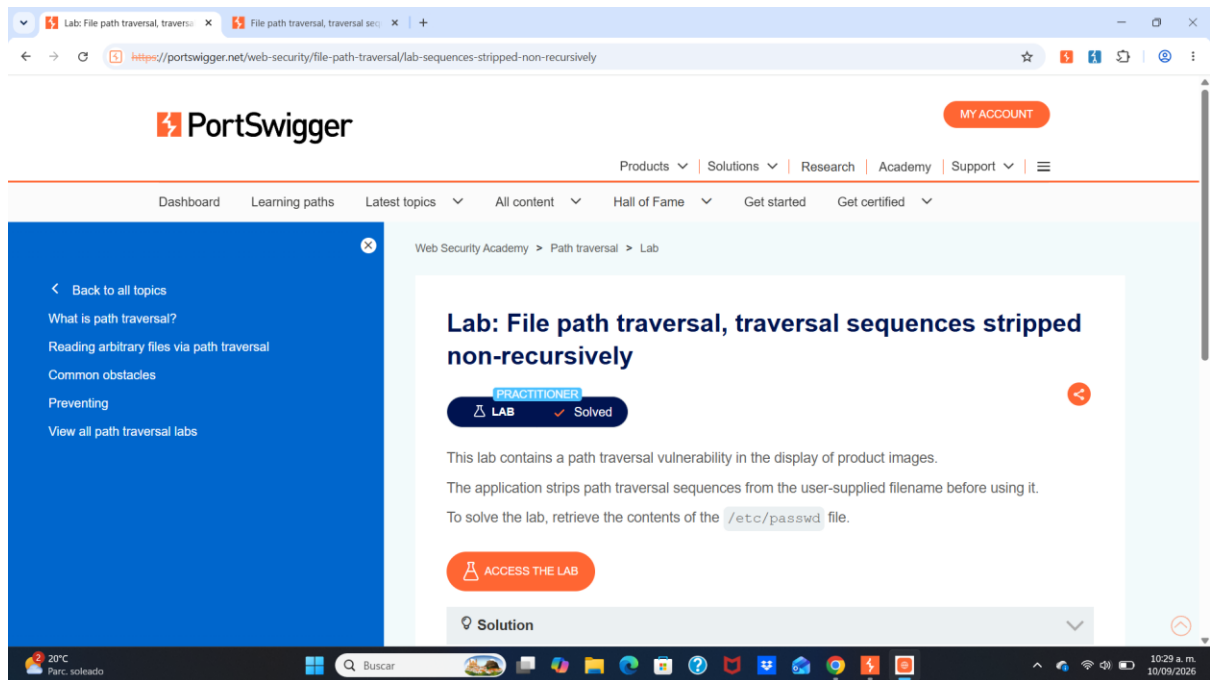
Este bypass expone la debilidad central de la estrategia de lista negra (o eliminación): intenta enumerar todos los patrones "malos", pero el atacante siempre puede encontrar expresiones equivalentes fuera de esa enumeración. MITRE clasifica el directory traversal como una categoría de vulnerabilidad "imperdonable", precisamente porque sus métodos de defensa se comprenden plenamente desde hace tiempo, pero las implementaciones erróneas siguen siendo comunes. La práctica correcta no es intentar filtrar, sino verificar si la entrada pertenece a un conjunto conocido de valores "buenos".

Posibles Soluciones

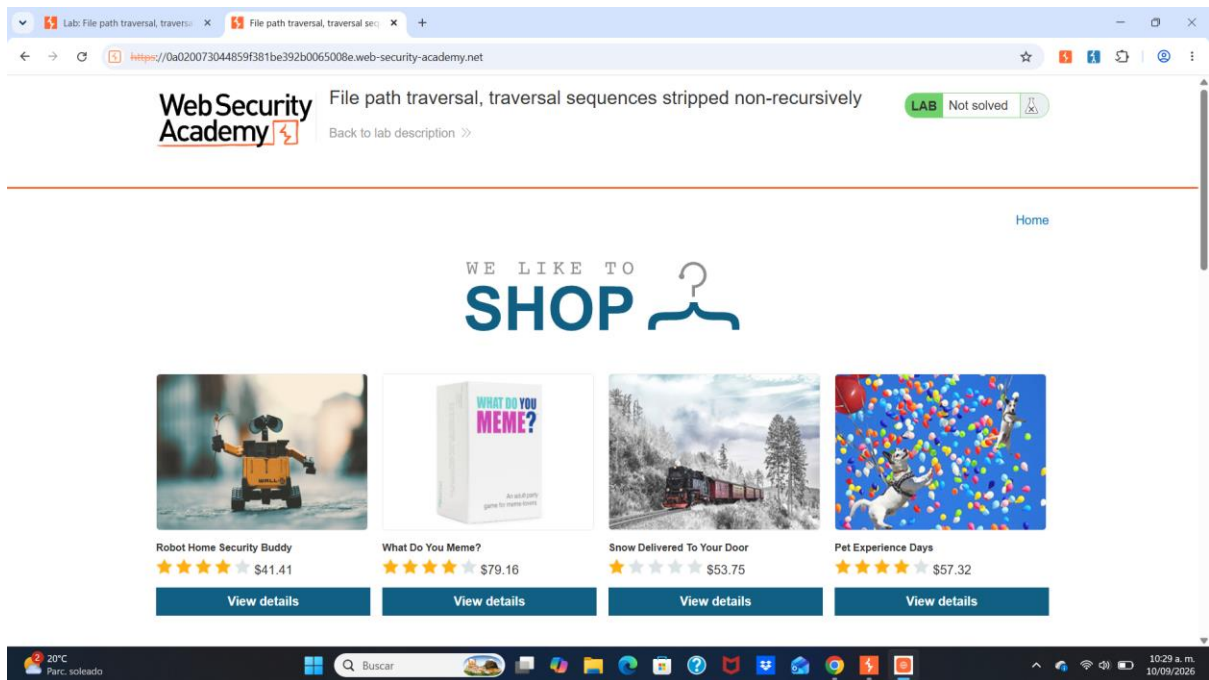
Para evitar esta vulnerabilidad, la defensa no debe basarse en eliminar o filtrar cadenas como ../, ya que un atacante puede usar secuencias anidadas (....//) para reconstruir la secuencia prohibida. La solución correcta consiste en normalizar la ruta resultante con realpath() y verificar que permanezca dentro del directorio permitido,

rechazando cualquier acceso que intente salir de él. Además, se recomienda implementar una lista blanca de archivos permitidos, usar identificadores numéricos en lugar de nombres de archivo, y aplicar permisos restrictivos para que el usuario del servidor web no pueda leer archivos sensibles del sistema. La combinación de estas capas garantiza que, sin importar cómo el atacante construya la entrada, el destino final siempre esté validado y sea seguro.

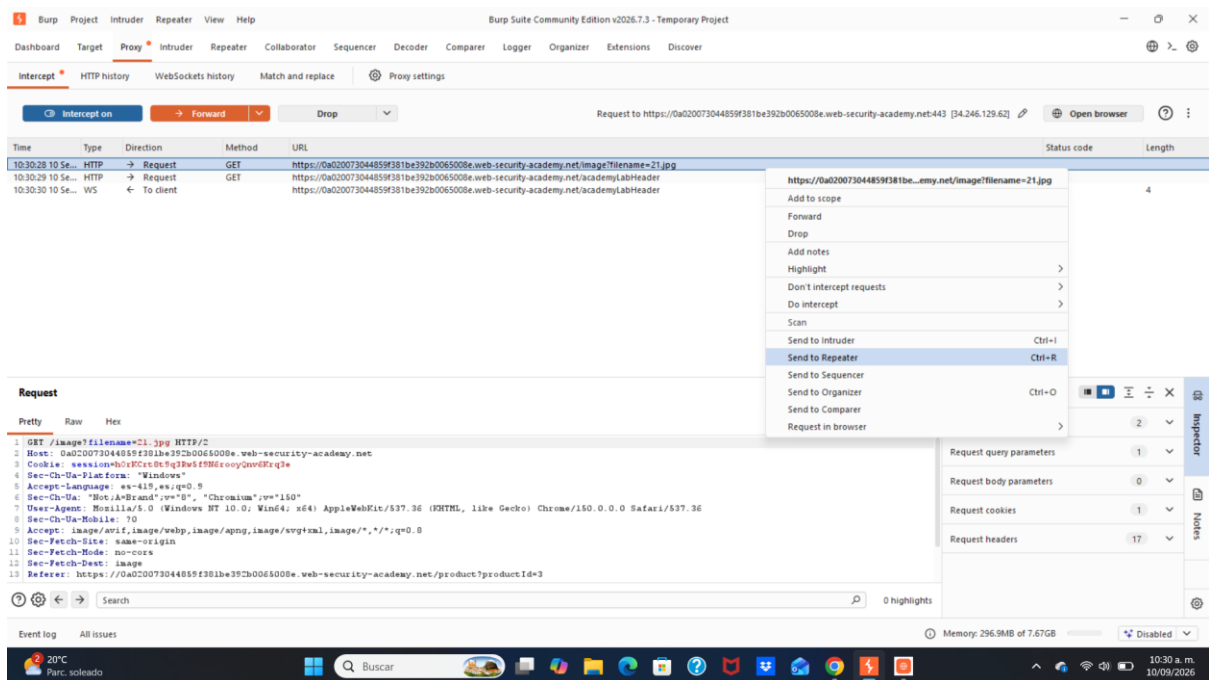
Desarrollo



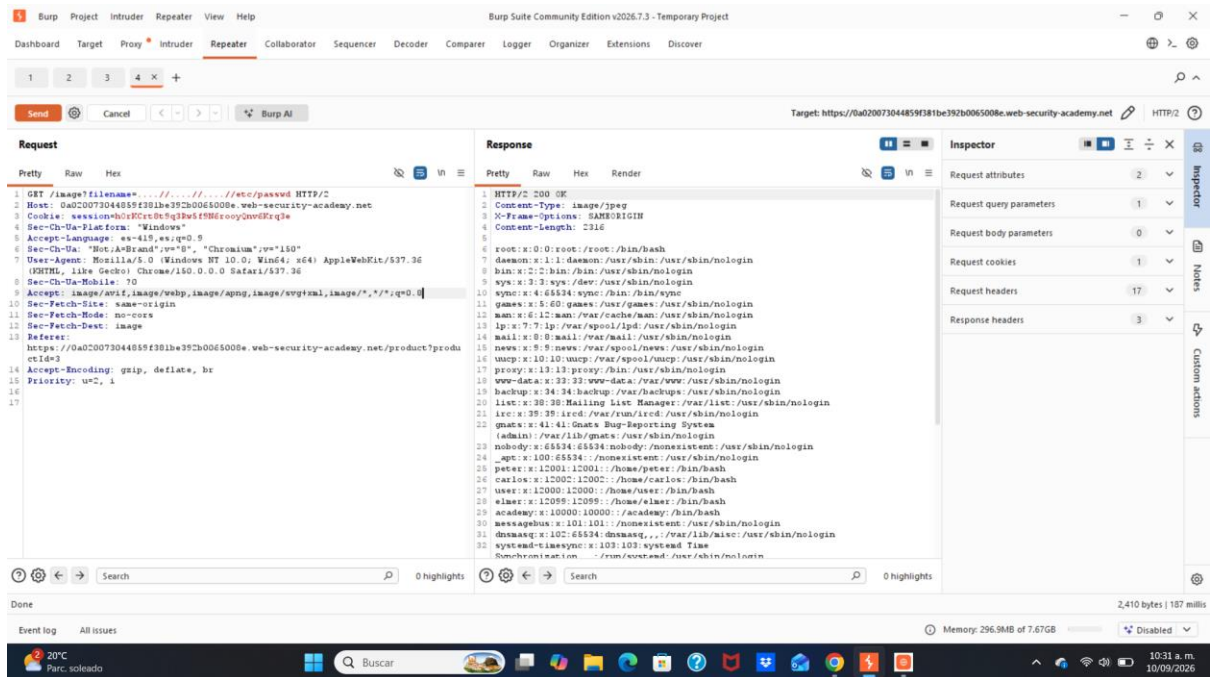
Copiamos la URL dentro del navegador que nos proporciona burpsuite, nos mandara directamente a la actividad de Traversal sequences stripped non-recursively



Una vez entremos a la pagina web de la actividad, daremos click en cualquier imagen en la parte de “View details”, para empezar a recibir el trafico y poder analizarlo.



Una vez empiece a llegar el tráfico, nos iremos a nuestro burpsuite e iremos a la parte de “Proxy” y daremos click en forward en los logs que no nos interesen, nos enfocaremos en los logs de tipo imagen “jpg”, una vez lo encontremos lo mandaremos al repetidor donde lo analizaremos a profundidad.



Nos moveremos a la parte del repetidor donde analizaremos el log de tipo img, en la parte de request veremos código de tipo html y nos enfocaremos en la parte que dice “filename” y borraremos lo que se encuentre ahí para escribir “../../../../etc/passwd”, a diferencia de los casos anteriores, en esta actividad se bloquea el caso simple y la ruta universal de path traversal, mas no la vulnerabilidad de secuencias anidadas, que es la que estamos efectuando para poder obtener acceso al directorio /etc/passwd de donde obtendremos usuarios y passwords encriptadas.

Conclusión

Este laboratorio ofrece una lección importante sobre el diseño de defensas de seguridad: las defensas basadas en eliminación o listas negras son intrínsecamente frágiles, porque dependen de una enumeración completa de los patrones de ataque, mientras que la creatividad del atacante es infinita. El bypass de la eliminación no recursiva aprovecha precisamente un descuido en el detalle de implementación: una operación aparentemente razonable de "eliminar caracteres peligrosos" resulta completamente ineficaz frente a entradas anidadas cuidadosamente construidas.

Desde la perspectiva del defensor, la solución correcta no es intentar eliminar de forma más inteligente, sino adoptar una estrategia de lista blanca: enumerar explícitamente los archivos a los que se permite acceder, o utilizar un diseño que no implique rutas de archivo proporcionadas por el usuario (como mapear archivos mediante identificadores aleatorios). Si es imprescindible procesar rutas proporcionadas por el usuario, se debe verificar, tras la normalización, que la ruta resultante esté estrictamente dentro del directorio seguro previsto, en lugar de intentar identificar y eliminar secuencias "maliciosas". Este cambio de mentalidad es la clave para pasar de "parchear cada vulnerabilidad conocida" a "eliminar de raíz la categoría de vulnerabilidad".